VULNERABILITY ASSESSMENT REPORT

Passive Security Assessment of testphp.vulnweb.com

THULISILE MALULEKE

TOOLS USED:
NMAP | OWASP ZAP | BROWSER DEVTOOLS

25 FEBRUARY 2026

EXECUTIVE SUMMARY

This report presents the results of a passive vulnerability assessment conducted on the public website testphp.vulnweb.com. The objective of this assessment was to identify visible security weaknesses without performing any intrusive or exploitative testing. The assessment identified several configuration-related vulnerabilities, including lack of HTTPS enforcement, missing security headers, and server version disclosure. While no active exploitation was performed, these issues may increase the risk of cyberattacks if left unaddressed.

This report provides risk classifications and practical remediation recommendations to improve the overall security posture of the website.

SCOPE & ETHICS

Scope of Assessment

- Public-facing pages only
- Passive scanning techniques
- No login attempts
- No exploitation performed
- No denial-of-service activity

Ethical Compliance

The assessment was conducted in accordance with ethical security testing principles. The tested website is an intentionally vulnerable public training platform maintained by Acunetix for educational purposes.

METHODOLOGY

The following tools were used:

1. Nmap – To identify open ports and exposed services
2. OWASP ZAP (Passive Scan) – To identify security misconfigurations
3. Browser Developer Tools – To inspect HTTP response headers

All testing was performed using passive, non-intrusive techniques.

FINDINGS TABLE

ID	Vulnerability	Risk	Description	Recommendation
01	No HTTPS Enforcement	HIGH	The website allows unencrypted HTTP communication over port 80.	Implement SSL/TLS certificate and redirect HTTP to HTTPS.
02	Missing HSTS Header	HIGH	The website does not enforce secure HTTPS connections.	Enable Strict-Transport-Security header.
03	Missing Content Security Policy	MEDIUM	No restrictions on script execution, increasing risk of XSS attacks.	Implement Content-Security-Policy header
04	Missing X-Frame-Options	MEDIUM	Website may be vulnerable to clickjacking attacks	Add X-Frame-Options header.
05	Timestamp Disclosure	LOW	Server reveals internal timestamp format information.	Minimize unnecessary information disclosure

PRIORITIZED REMEDIATION PLAN

Immediate Actions (High Priority)

- Implement HTTPS across the entire website
- Enable HSTS

Short-Term Improvements (Medium Priority)

- Add Content-Security-Policy header
- Add X-Frame-Options header
- Hide server version information

Long-Term Improvements (Low Priority)

- 6Review cache control policies
- Minimize server information disclosure

CONCLUSION

The assessment revealed several configuration-level vulnerabilities that could expose the website to security risks in a production environment. Addressing the identified high and medium-risk issues will significantly strengthen the site's security posture and reduce exposure to common web-based attacks.